

Bash Script Check

Transformer za procenu bezbednosti skripti

CILJ PROJEKTA

Automatska klasifikacija Bash skripti kao bezbednih, rizičnih ili zlonamernih, uz dodatno objašnjenje tipa zlonamernog ponašanja.

4.000

uzoraka

3

glavne klase

98,51%

tačnost razloga

1. Sažetak projekta

Bash Script Check je eksperimentalni sistem za statičku analizu teksta shell skripti. Model ne izvršava kod, već iz njegovih tokena predviđa jednu od tri klase: safe (bezbedno), risky (rizično) ili malicious (zlonamerno). Za zlonamerne uzorke drugi klasifikacioni izlaz procenjuje kategoriju ponašanja, na primer reverse shell, eksfiltraciju ili perzistenciju.



Najvažniji nalaz

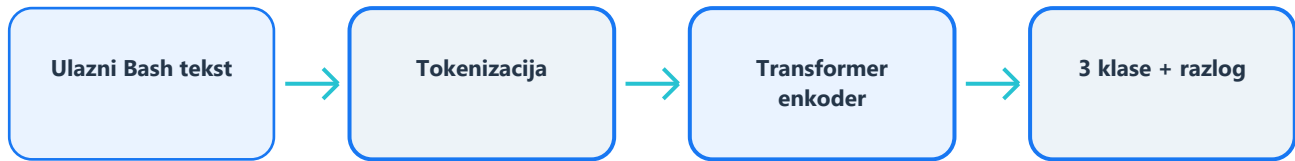
Sačuvani checkpoint je na reproduktivnom, stratifikovanom test skupu od 801 uzorka tačno klasifikovao svih 801 primera. Ovaj rezultat je tehnički ispravno izmeren, ali je verovatno optimističan: bezbedni i rizični primeri su uglavnom generisani iz ograničenog broja šablona, pa test skup nije potpuno nezavisan od obrasca trening podataka.

Praktična interpretacija: model je veoma uspešan na podacima istog porekla, ali pre produkcione upotrebe mora se proveriti na novom, ručno označenom skupu iz drugih repozitorijuma i organizacija.

Ključne karakteristike

Element	Opis
Ulaz	Bash/shell skripta kao običan tekst; nema izvršavanja
Model	Encoder-only Transformer sa dva klasifikaciona izlaza
Primarni izlaz	safe / risky / malicious
Sekundarni izlaz	7 kategorija zlonamernog ponašanja
Interfejs	CLI tokovi za CPU, GPU i predikciju showcase skripti

2. Arhitektura i tok obrade



Skripta se tokenizuje WordLevel tokenizatorom sa whitespace pre-tokenizacijom. Sekvenci se dodaje [CLS] token i ograničava se na kontekst od 384 tokena. Četiri Transformer enkoderska bloka formiraju reprezentaciju, a prosečno objedinjavanje validnih tokena prosleđuje se u dve linearne glave.

Konfiguracija sačuvanog modela

Parametar	Vrednost	Značenje
Dimenzija modela	192	širina embeddings/skrivenih reprezentacija
Attention glave	6	paralelni obrasci pažnje
Encoder blokovi	4	dubina Transformer enkodera
Feed-forward sloj	768	unutrašnja FFN dimenzija
Maks. kontekst	384 tokena	duže skripte se skraćuju
Dropout	0,10	regularizacija tokom treninga

Trening

Checkpoint je treniran 12 epoha, batch veličinom 32, AdamW-kompatibilnim parametrima learning rate 3×10^{-4} i weight decay 1×10^{-4} . Ukupni gubitak kombinuje klasifikaciju glavne klase i klasifikaciju razloga, sa težinom sekundarnog gubitka 0,5.

Bezbednosna granica sistema

Sistem je statički klasifikator, a ne sandbox. Ne prati tokove podataka kroz izvršavanje, ne razrešava dinamički generisan kod i ne može garantovati da je skripta bezbedna. Predikcija safe zato nikada ne sme automatski da odobri izvršavanje nepoznate skripte.

3. Podaci i poreklo uzoraka

Projektni tok podataka obuhvata tri izvora: sintetički generisane bezbedne i rizične skripte, scrapeovane GitHub shell skripte sa heurističkim oznakama i Red Team Operations Shell Script Dataset sa Hugging Face-a za zlonamerne primere. Fajl korišćen za trenutni checkpoint sadrži 4.000 redova; u njemu se jasno potvrđuju sintetički safe/risky identifikatori i 1.000 RTO zlonamernih uzoraka. GitHub scraper postoji kao ulazni kanal, ali kombinovani artefakt ne čuva dokaz da je svaki scrapeovani zapis uključen u ovaj konkretan trening.

Raspodela glavnih klasa

Klasa	Broj	Udeo	Tipični sadržaj
safe	1.500	37,5%	lokalna automatizacija, provere, build i backup
risky	1.500	37,5%	sudo, sistemske izmene, brisanje, firewall
malicious	1.000	25,0%	RTO tehnike i ofanzivne komande
Ukupno	4.000	100,0%	JSONL skup za trening i evaluaciju



Grafik 1. Relativna veličina klasa (najveća klasa = 100%).

Poreklo i kontrola kvaliteta

Izvor	Uloga	Kontrola / rizik
Sintetički generator	safe i risky varijante iz parametrizovanih šablona	deduplikacija SHA-1; moguć šablonski bias
GitHub scraping	realne install/deploy/admin skripte	heurističke oznake; obavezna ručna provera i licenca
Hugging Face RTO	1.000 malicious uzoraka i kategorije ponašanja	kurirani skup; proveriti format i nezavisnost evaluacije

4. Evaluacija modela

Evaluacija je reprodukovana nad sačuvanim checkpoint-om. Skup je stratifikovano podeljen seed-om 42 i test frakcijom 20%, uz očuvanje glavnih klasa i kategorija zlonamernog ponašanja. Zbog zaokruživanja po podgrupama izdvojeno je 801 test primera: 300 safe, 300 risky i 201 malicious.

Glavni skorovi



Grafik 2. Rezultati na reproduktivnom izdvojenom test skupu.

Metrika	Skor	Broj uzoraka	Tumačenje
Accuracy	100,00%	801	udeo tačnih predikcija glavne klase
Macro-F1	100,00%	801	jednaka težina za sve tri klase
Reason accuracy	98,51%	201 malicious	tačnost dodatne kategorije napada

Metričke definicije

Precision meri koliko je predikcija date klase ispravno; recall meri koliko je stvarnih primera klase pronađeno; F1 je harmonijska sredina precision-a i recall-a. Macro-F1 je aritmetička sredina F1 skorova klase i zato ne favorizuje većinsku klasu.

Važna napomena

Rezultat od 100% nije dovoljan dokaz generalizacije. Najverovatniji uzroci su ograničen broj generator šablona, varijante istih obrazaca u train/test podeli i karakterističan stil RTO korpusa. Potrebna je evaluacija po izvorima (group split), kao i potpuno eksterni test skup.

5. Detaljni rezultati

Rezultati po klasi

Klasa	Precision	Recall	F1	Podrška
safe	100,00%	100,00%	100,00%	300
risky	100,00%	100,00%	100,00%	300
malicious	100,00%	100,00%	100,00%	201
macro prosek	100,00%	100,00%	100,00%	801

Matrica konfuzije

Redovi predstavljaju stvarne, a kolone predviđene klase.

stvarno \ predviđeno	safe	risky	malicious
safe	300	0	0
risky	0	300	0
malicious	0	0	201

Kategorije zlonamernog ponašanja

Kategorija	Broj u skupu	Test podrška	Napomena
recon	217	43	1 primer zamenjen sa defense_evasion
reverse_shell	195	39	svi tačni
exfiltration	195	39	1 primer zamenjen sa recon
defense_evasion	194	39	svi tačni
persistence	193	39	svi tačni
obfuscation	4	1	premalo za pouzdan zaključak
privilege_escalation	2	1	premalo; primer zamenjen sa recon

6. Ograničenja i preporuke

Glavni rizici validnosti

Rizik	Posledica	Preporučena mera
Šablonski sintetički podaci	model može učiti stil generatora	group split po šablonu i više realnih primera
Heurističke scrape oznake	pogrešno označavanje safe/risky	dvostruka ručna anotacija i zapis saglasnosti
Neravnoteža razloga	slaba procena retkih kategorija	dopuniti obfuscation i privilege_escalation
Sličnost izvora	prenaduvani test skorovi	eksterni test iz novih repozitorijuma
Skraćivanje na 384 tokena	kritičan deo duge skripte može biti odsečen	segmentna analiza i agregacija rezultata
Statička analiza	dinamički/obfuskovani kod može proći	kombinovati sa sandbox-om i pravilima

Preporučeni sledeći koraci

1. Formirati potpuno nezavisan, ručno označen test skup sa najmanje 200 primera po glavnoj klasi.
2. Uvesti group split po šablonu, repozitorijumu i izvoru kako srodni primeri ne bi završili u oba dela.
3. Izveštavati weighted-F1, macro-F1, ROC/PR po klasi i intervale pouzdanosti, uz matricu konfuzije.
4. Kalibrisati confidence skorove i definisati zonu neodlučnosti koja zahteva ljudski pregled.
5. Čuvati provenance i licencu za svaki scrapeovani zapis; ne distribuirati kod bez provere dozvole.

Zaključak

Projekat predstavlja funkcionalan end-to-end prototip za tekstualnu procenu Bash skripti: ima pripremu podataka, tokenizator, Transformer model, CPU/GPU trening, evaluaciju i komandnu predikciju. Interni rezultati su odlični, posebno glavni klasifikacioni izlaz. Najveći sledeći doprinos nije dodatno optimizovanje modela, već stroža i nezavisnija validacija podataka.

Izvori

[1] Lokalni repozitorijum: README.md, generate_dataset.py, scrape_dataset.py, bash_classifier/*, data/*.jsonl i artifacts/bash_transformer.pt.

[2] Hugging Face: [darkknight25/Red_Team_Operations_ShellScript_Dataset](#) (1.000 RTO skripti, MIT licenca prema dataset kartici).

[3] Rezultati u ovom izveštaju reprodukovani su lokalno iz checkpoint-a i stratifikovane podele seed=42.